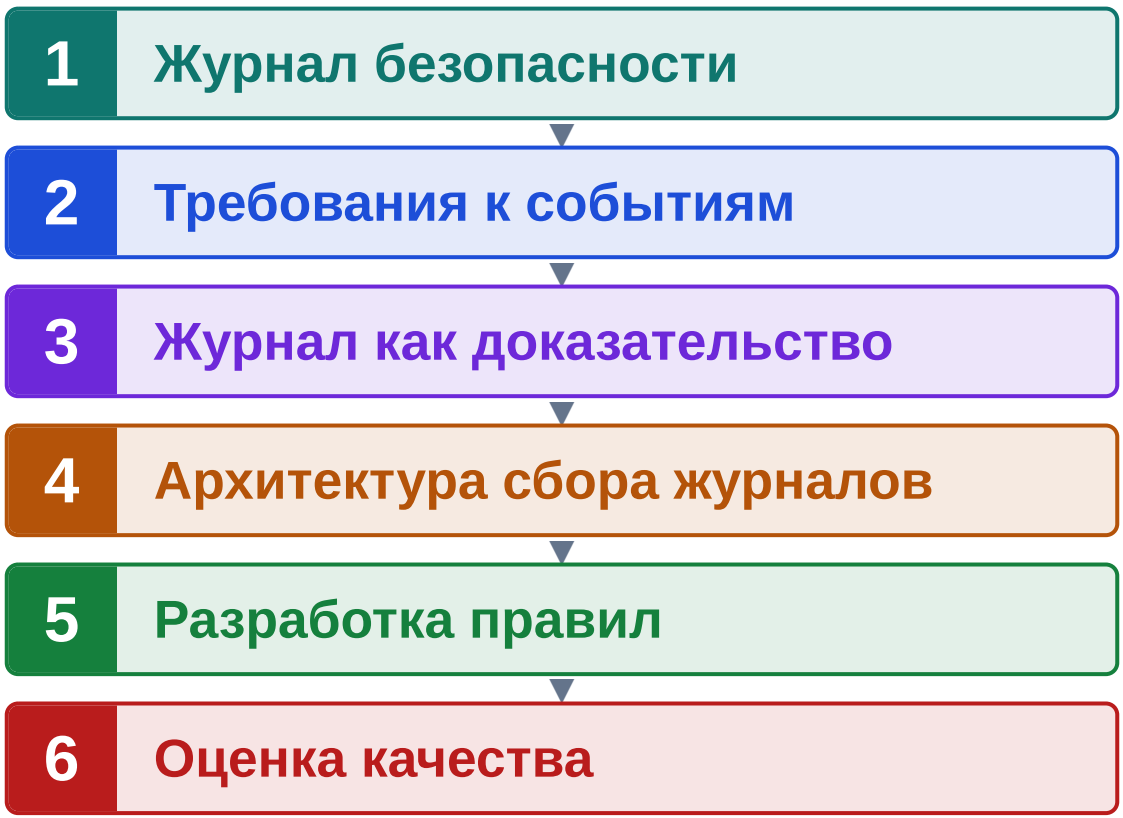
Методы и принципы проектирования современных защищённых систем

Лекция 3

Журналирование и обнаружение событий безопасности

Требования к событиям · доказуемость · архитектура · качество срабатываний

План лекции


1
Журнал безопасности
2
Требования к событиям
3
Журнал как доказательство
4
Архитектура сбора журналов
5
Разработка правил
6
Оценка качества

1

Журнал безопасности

что регистрируем и зачем

От события к инциденту

РЕГИСТРАЦИЯ

Источник событий → Событие безопасности → Запись о событии → Журнал безопасности

АНАЛИЗ

Правило обнаружения → Сигнал → Разбор аналитиком → Инцидент

> Событие указывает лишь на **возможное** нарушение — значимость устанавливается при анализе, а не при записи

Одна неудача — норма, серия — сигнал

	09:00	09:01	09:02	09:03	09:04	09:05	09:06	09:07
Пользователь			✗✓					
Нарушитель		✗✗✗	✗✗✗	✗✗✗	✗✗✗	✗✗✗	✗✗✗	✗✗✓

1 неудача
опечатка в пароле — **норма**

vs

20 неудач за 7 мин
возможен подбор пароля

Значимость события определяется **в контексте** других событий — поэтому регистрируются и штатные действия

Журнал безопасности ≠ эксплуатационный журнал

	Эксплуатационный	Безопасности
Содержание	ошибки, время ответа, ход выполнения запросов	кто, что и над каким объектом сделал, с каким результатом: входы, изменения прав, доступ к данным
Хранение	дни – недели	месяцы – годы
Доступ	широкий круг инженеров	ограничен, разделение полномочий
Целостность	желательна	обязательна, изменения обнаруживаются

> Записи о событиях безопасности — в отдельное хранилище со своими правами и сроками

Четыре задачи журнала

Обнаружение	Расследование	Доказательство	Данные для моделей
все ключевые события, малая задержка доставки	контекст, связь записей разных компонентов, срок хранения	целостность, достоверное время, привязка к субъекту	модель не увидит то, что не записано

Журналирование — **проектное решение**: принимается вместе с архитектурой на основе модели угроз

Кейс: обнаружение SUNBURST, 2020

Событие 2FA
к учётной записи сотрудника добавлено второе устройство

→

Низкая важность
обычная операция с фактором аутентификации

→

Проверка
аналитик звонит сотруднику: «устройство не моё»

→

Инцидент
вскрыта атака на цепочку поставок

Операции с факторами аутентификации — **обязательная** категория событий

Событие низкой важности может быть **единственным** следом атаки

От угроз к каталогу событий

Угроза	Что делает нарушитель	Что записывает система	Тип события
Подбор пароля	перебирает пароли к чужой учётной записи	каждую попытку входа; блокировку после серии неудач	`auth.login` `auth.lockout`
SQL-инъекция	вводит в поиск фрагмент команды для базы данных	блокировку запроса межсетевым экраном	`waf.request.block`
Повышение привилегий	пытается получить права администратора	назначение ролей, отказы в доступе к администрированию	`iam.role.assign` `authz.access`
Доступ к чужим данным	подставляет в адрес номер чужого заказа	отказ в доступе к объекту	`authz.access`

> Система записывает **факты**; «подбор пароля» — уже **вывод** правила обнаружения

2

Требования к событиям

состав · структура · запреты · ошибки

Что регистрировать

Аутентификация

вход, выход, блокировка

Авторизация и привилегии

отказ в доступе, назначение ролей

Защищаемые данные

просмотр, выгрузка, удаление

Администрирование

конфигурация, хранилище секретов

Ошибки безопасности

проверка ввода, подписи, маркера

Сеть и программный интерфейс

частота запросов, блокировки экраном

Подсистема регистрации

остановка агента, удаление записей

Ослабление регистрации — типичный шаг нарушителя (ATT&CK T1562, T1070)

Запись о событии отвечает на вопросы

Пользователь **anna** 15 июля в 11:23 по Москве пыталась войти и ввела **неверный пароль**

Когда?	`"timestamp": "2026-07-15T08:23:45+00:00"`
Что произошло?	`"event_type": "auth.login"`
Чем закончилось?	`"outcome": "failure"`
Кто?	`"actor": {"type": "user", "id": "anna"}`
Откуда?	`"source_ip": "203.0.113.42"`
Кто записал?	`"service": "auth-service"`
Подробности?	`"context": {"reason": "bad_password"}`

Результат — в отдельном поле `outcome`

Время в UTC: 08:23 UTC = 11:23 МСК

Чего не должно быть в журнале

	✗ нельзя		✓ правильно
1. Пароль	`"password": "qwerty123"`	→	`"reason": "bad_password"`
2. Токен	`"token": "eyJhbGciOi…"`	→	`"token_hash": "3f9a1c"`
3. Номер карты	`"card": "4276 1600 1234 5678"`	→	`"card": "****5678"`
4. Почта, телефон	`"email": "anna@mail.example"`	→	`"actor": "anna"`
5. Одноразовый код	`"otp": "482913"`	→	не записывать — только результат проверки

Пароль или токен в журнале — вход от имени пользователя для любого, кто читает журнал

Типичные ошибки и их цена

Неструктурированные записи, разбор регулярными выражениями	→	правила ломаются при смене текста
Разнородные форматы и имена полей	→	записи не сопоставить
Записи разных частей системы ничем не связаны	→	цепочку действий не восстановить
Регистрируются только неудачи	→	успех атаки не виден
Изменяемое хранилище записей	→	нарушитель стирает следы
Отладочный уровень записи в эксплуатации	→	утечка данных, рост объёма
Пользовательский ввод без обработки (CWE-117)	→	подделка записей

Log4Shell: строка, записанная в журнал, запустила на сервере код нарушителя

Международные практики

OWASP ASVS 5.0 · V16
проверяемые требования: события, защита журналов, ошибки

OWASP Top 10:2025 · A09
ошибки журналирования и оповещения: CWE-778, CWE-117, CWE-532

OWASP Logging Cheat Sheet
практические рекомендации по составу и защите записей

NIST SP 800-92
управление журналами в масштабе предприятия

3

Журнал как доказательство

Модель угроз STRIDE

S	T	R	I	D	E
Spoofing	Tampering	Repudiation	Information disclosure	Denial of service	Elevation of privilege
Подмена личности	**Подделка данных**	**Отказ от действий**	**Раскрытие информации**	**Отказ в обслуживании**	**Повышение привилегий**

Журнал как доказательство — главная мера против **R**: достоверно записанное действие бессмысленно отрицать

Пять свойств доказательного журнала

Полнота регистрации

Целостность

Достоверность времени

Привязка к субъекту

Сохранность

Цепочка хеш-значений

ИСХОДНАЯ ЦЕПОЧКА хеш записи считается из её события и ссылки; ссылка = хеш предыдущей записи

Запись 1
вход u-1042
ссылка `0000`
хеш `7c1e`

→

Запись 2
роль admin → u-2001
ссылка `7c1e`
хеш `5d20`

→

Запись 3
выгрузка отчёта
ссылка `5d20`
хеш `91ab`

→

Запись 4
выход u-1042
ссылка `91ab`
хеш `c4f2`

ПОСЛЕ ПОДМЕНЫ ЗАПИСИ 2 хеш пересчитался → ссылка в записи 3 не совпадает

Запись 1
вход u-1042
ссылка `0000`
хеш `7c1e`

→

Запись 2
роль admin → **u-6666**
ссылка `7c1e`
хеш `e81b`

✗

Запись 3
выгрузка отчёта
ссылка `5d20`
хеш `91ab`

→

Запись 4
выход u-1042
ссылка `91ab`
хеш `c4f2`

✓ **видно:** изменение и удаление в середине

✗ **не видно:** обрезку хвоста, пересчёт цепочки

поэтому последний хеш периодически фиксируют **вне** хранилища

Сроки хранения



SUNBURST: от первых действий нарушителя до обнаружения — **более года**

4

Архитектура сбора журналов

от источника до аналитика

Промышленная система сбора и анализа журналов



Ключевые архитектурные решения

Нормализация у источника
правила пишутся в терминах одной схемы: собственной, ECS / OpenTelemetry или OCSF

Брокер сообщений
отказ хранилища ≠ потеря записей; новые правила можно применить к старому потоку

Потоковая обработка
правило проверяется на каждой записи — минимальная задержка

Обработка по расписанию
запрос к хранилищу — вся история, но задержка ≥ периода запуска

Открытые SIEM: сравнение

Решение	Лицензия	Правила и Sigma	Сильная сторона
Wazuh	**GPLv2 / Apache 2.0**	XML, 3000+ готовых; Sigma — с версии 5.0	агенты: целостность файлов, конфигурация, уязвимости
OpenSearch Security Analytics	**Apache 2.0**	Sigma встроена, корреляция находок	полностью открытый стек
Elastic Security	**AGPL / SSPL / ELv2**	KQL, EQL, ES|QL; Sigma через pySigma	расследование; ML — платно
Grafana Loki	**AGPLv3**	LogQL; Sigma через pySigma	дешёвое хранение, индекс меток
Graylog Open	**SSPL**	потоки и оповещения	сбор и разбор; безопасность — платно
Security Onion	**ELv2**	Sigma, YARA, Suricata	готовая платформа с сетевыми датчиками

OSI-лицензия **код открыт, есть ограничения на услугу** + DFIR-IRIS (инциденты), Shuffle (реагирование)

Пирамида обработки сигналов



единицы в неделю

единицы–десятки в сутки

десятки–сотни

сотни–тысячи сигналов

тысячи срабатываний

миллионы–миллиарды в сутки

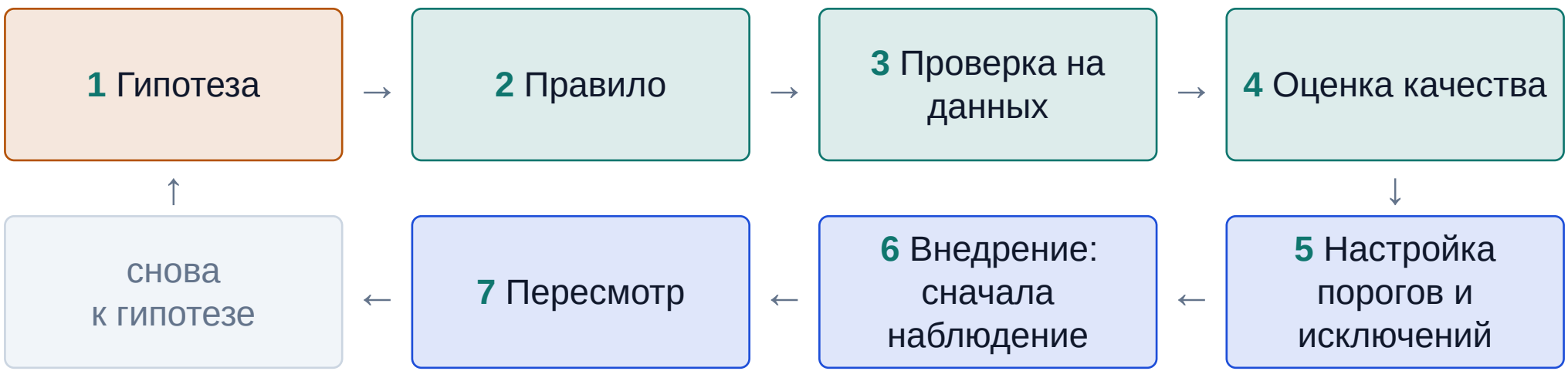
Обратная связь: каждое ложное срабатывание, отсеянное 1-й линией, — повод настроить правило

5

Разработка правил

гипотеза · окна · Sigma · ATT&CK

Жизненный цикл правила



Правило — инженерное изделие: версия, тесты, показатели качества, владелец

Гипотеза обнаружения

Действие	Если нарушитель делает X	подбирает пароль (T1110.001)
Источник	то в журнале S	сервиса аутентификации
След	появится след Z	серия `auth.login` с неудачей
Отличие	отличающийся признаком P	одна учётная запись, короткое время
Легитимно	но так бывает, когда W	забыт пароль; приложение со старым паролем

> Последняя строка заранее называет **будущие ложные срабатывания**

Четыре вида правил

Одиночное событие



отключение 2FA
состояние не нужно

Агрегация по окну



5 неудач за 10 мин
счётчики по ключу

Цепочка событий



неудачи → успешный вход
пройденные шаги

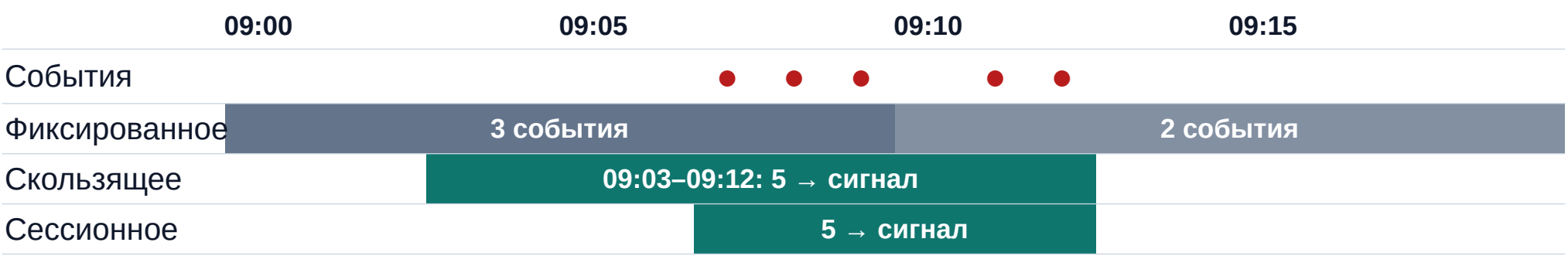
Корреляция источников

A + B + C

подбор → вход → выгрузка
несколько потоков

выразительность, затраты и зависимость от качества данных растут →

Окно агрегации: где теряется серия



окно

интервал подсчёта

ключ

поле группировки

порог

значение для сигнала

Ключ группировки решает, что видно

Ключ · величина	Подбор к одной записи	Подбор с многих адресов	Распыление паролей
Учётная запись · число неудач	✓	✓	✗
Адрес · число неудач	✓	✗	✓
Адрес · число **различных** учётных записей	✗	✗	✓

> В SecureShop подбор остановит блокировка, а распыление — нет: правило нужнее именно для него

Правило Sigma на пальцах

Задача: «Сообщи, если кто-то неудачно вошёл под учётной записью **admin**»

```
title: Неудачный вход под admin
```

Название

```
logsource: {service: auth}
```

Где искать? журнал аутентификации

```
detection:
  selection:
    event_type: auth.login
    outcome: failure
    actor.id: admin
```

Что ищем? все три условия сразу

```
  condition: selection
```

Когда сигнал? когда условия выполнены

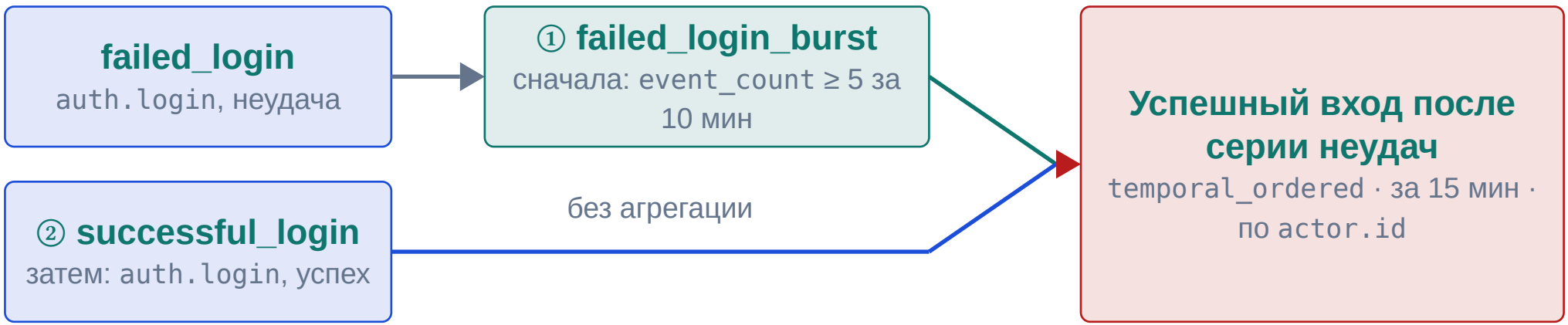
```
level: medium
```

Насколько важно? средняя важность

```
{"event_type": "auth.login", "outcome": "failure", "actor": {"id": "admin"}}
```

→ ✓ **сигнал**

Корреляция в Sigma 2



Сигнал — только если для одной учётной записи шаги ① и ② произошли **именно в этом порядке** и уложились в 15 минут

`event_count`	`value_count`	`temporal`	`temporal_ordered`
число событий	различные значения	все в окне	в заданном порядке

Устаревшая запись: `condition: selection | count() > 5` с полем `timeframe`

Сопоставление с MITRE ATT&CK

Доступ к учётным данным	T1110.001 подбор; T1110.003 распыление; T1556.006 2FA
Первоначальный доступ	T1078 действительные учётные записи
Закрепление / привилегии	T1098 изменение учётных записей
Сбор данных	T1213 информационные хранилища
Обход защиты	T1562 ослабление защиты

> Покрытие техники ≠ правило на технику: правило видит конкретный способ, а не технику целиком

6

Оценка качества

Precision · Recall · ложные срабатывания

Матрица ошибок и показатели

	атака была	атаки не было
сработало	**TP** истинное	**FP** ложное
не сработало	**FN** пропуск	**TN** не определено

$$\text{Precision} = \frac{\text{TP}}{\text{TP} + \text{FP}}$$

доля полезных сигналов · считается **по сигналам**

$$\text{Recall} = \frac{\text{TP}}{\text{TP} + \text{FN}}$$

доля обнаруженных атак · считается **по сценариям**

Ловушка базовой частоты

10^6 событий в сутки × **0,1 %** ложных на событие = **≈ 1000** FP в сутки vs **≈ 5** TP в сутки

Precision ≈ 5 / 1005 < **1 %**

Малая доля ошибок на событие ещё не означает пригодности правила

Снижение ложных срабатываний — у всего есть цена

Порог

выше порог или длиннее серия

цена: медленная атака ниже порога

Исключения

сканер, служебные учётные записи

цена: нарушитель от их имени невидим

Объединение

повторы → один сигнал

цена: теряется масштаб атаки

Контекст

роль, значимость узла, репутация адреса

цена: зависимость от справочников

Оценка риска

баллы субъекту, сигнал по сумме

цена: труднее объяснить сигнал

Подавление

плановая выгрузка, резервное копирование

цена: нарушитель имитирует процесс

Кейс: Target, 2013

Обнаружено
система фиксирует установку вредоносного ПО

→

Предупреждено
мониторинг дважды передаёт сигнал

→

Не сделано
мер не принято, автоудаление отключено

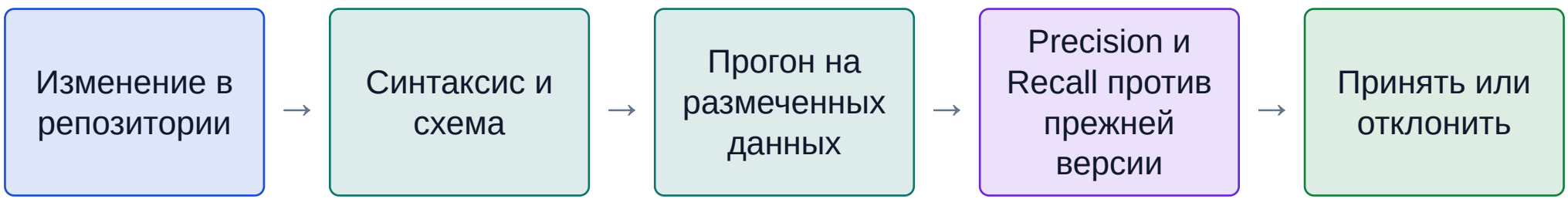
→

Итог
похищены данные 40 млн карт

Правило без процесса реагирования не защищает

Отказ от автоматической реакции — принятие риска, фиксируется явно

Правила обнаружения как программный код



Версии
история и откат

Проверка другим
ревью изменения

Регрессия качества
ухудшение не проходит

Главное

1 Журнал безопасности	Не записано — не обнаружено
2 Требования к событиям	Единый формат данных
3 Журнал как доказательство	Полнота, целостность, достоверность времени, привязка к субъекту, сохранность
4 Архитектура сбора	Сбор, доставка, хранение, обнаружение, разбор сигналов
5 Разработка правил	Правило превращает журнал из архива в средство обнаружения атак
6 Оценка качества	Каждое правило нужно оценивать: точность (Precision) и полнота (Recall)

Методы и принципы проектирования современных защищённых систем

Лекция 3

Журналирование и обнаружение событий безопасности

Требования к событиям · доказуемость · архитектура · качество срабатываний